RED TEAM TECHNICAL ANALYSIS

AI 驱动渗透框架 ARTEX 技术拆解

从架构设计到致命暴露：一次完整的红队链路复盘

simon · 一个不懂代码的 AI 极客

微信交流群 simonsxxs

github.com/simonsxxs | gitee.com/simonsxx

技术分享 · 仅供安全研究与防御建设

目 录

第一章 事件总览与攻击面画像

1.1 攻击时间线与目标选择

1.2 受害面分析：外围系统为何成为突破口

1.3 泄露数据规模与影响评估

第二章 ARTEX 框架深度解析

2.1 框架定位：自主渗透测试 Agent

2.2 核心模块与调用链

2.3 多模型路由策略

第三章 双服务器架构与通信链路

3.1 架构设计思想：指挥与执行分离

3.2 流量走向与协议分析

3.3 代理层与会话隐匿

第四章 AI 辅助渗透的技术实现

4.1 侦察阶段：自动化信息收集

4.2 攻击阶段：外围系统入侵手法

4.3 载荷投递与数据提取

第五章 身份隐匿与反溯源策略

5.1 四层隔离架构

5.2 支付与注册匿名化

5.3 行为指纹控制

第六章 致命失误与暴露分析

6.1 目录浏览：一个默认配置的灾难

6.2 日志管理：自己写下的证据链

6.3 身份信息注入：Prompt 里的裸奔

第七章 防御视角与检测建议

7.1 资产暴露面收敛

7.2 AI 辅助攻击的检测特征

7.3 运维 Hygiene 检查清单

署名与联系

第一章 事件总览与攻击面画像

> *2026 年 9 月底至 10 月初，韩国多家金融机构遭遇集中网络攻击。攻击者利用中国开源 AI 渗透框架 ARTEX，结合多模型协同策略，在短时间内对至少 7 家机构实施入侵。本章从攻击者视角还原时间线、目标选择逻辑与受害面特征。*

1.1 攻击时间线与目标选择

攻击时间窗口高度浓缩。从 9 月下旬首波侦察到 10 月初 CrowdStrike 报告发布，整个活跃周期不足两周。这种"闪电战"模式高度依赖 AI 自动化——传统渗透测试团队需要数周完成的侦察与利用链构建，在 ARTEX 的辅助下被压缩到数天。

表 1 攻击时间线

时间	事件	技术意义
2026-07-26	ARTEX 框架在 GitHub 开源发布	攻击者获得核心工具，具备自主渗透能力
2026-09 下旬	首波网络侦察与扫描活动	针对韩国金融 IP 段进行自动化资产测绘
2026-09-30 至 10-05	多家金融机构外围系统遭入侵	集中利用窗口，AI 加速漏洞验证与利用
2026-10-07	CrowdStrike 发布调查报告	攻击者 IOC 与操作行为被完整还原
2026-10-08	攻击者 Telegram 频道回应	身份线索进一步被验证与关联

目标选择呈现明显的"避实击虚"特征。攻击者未触碰核心网银交易系统，而是专门瞄准**外围业务系统**：贷款经纪人查询 portal、员工移动办公支持系统、内部业务管理后台。这些系统的防护等级通常低于核心交易网，且与第三方存在大量数据接口，为自动化枚举提供了丰富入口。

1.2 受害面分析：外围系统为何成为突破口

金融机构的安全预算通常呈"内紧外松"的漏斗结构：核心交易系统层层设防，但外延到员工、渠道、合作伙伴的接口往往存在监控盲区。攻击者正是利用了这一结构性弱点。

以被确认的一类突破口为例——**贷款进度查询服务**。该系统面向金融机构经纪人开放，用于查询客户贷款审批状态。攻击者的入侵逻辑如下：

1. **接口发现**：通过子域名枚举与路径扫描，定位到该服务的对外开放端点
2. **参数分析**：捕获请求中的客户编号字段，发现其为顺序递增的纯数字格式

3. **批量枚举**：构造自动化脚本，在编号空间中遍历有效客户记录
4. **数据聚合**：将返回的姓名、电话、年收入、贷款额度等字段批量提取

这类系统通常缺乏针对高频顺序请求的速率限制与异常检测，使得自动化枚举可以在数小时内完成数万个客户记录的遍历。

1.3 泄露数据规模与影响评估

韩国金融安全院（FSI）与金融监督院（FSS）确认的受害机构包括 KB 国民银行、新韩银行、韩亚银行、BNK 釜山银行等。已公开的泄露数据规模如下：

表 2 各机构泄露数据概况

机构类型	泄露字段	规模（人）
大型商业银行（新韩等）	姓名、电话、年收入、贷款额度	约 25,000
储蓄银行（Yegaram 等）	个人身份信息、联系资料	约 40,000
其他受害机构	员工账户、内部业务数据	约 3,000+
合计	—	约 68,000

> **注意：数据口径存在矛盾**
>
> 部分外媒报道称 KB 国民银行泄露数据达 11.9 万人，与韩国官方口径合计 6.8 万存在显著差异。该差异可能源于：不同统计口径（去重前/去重后）、不同批次泄露、或外围系统与信用卡系统的叠加计数。目前官方未给出统一解释。

从红队视角评估，本次攻击的价值不在于数据本身的高敏感度（未涉及交易密码、CVV 等核心金融凭证），而在于**精准个人画像的批量获取**。姓名+电话+年收入+贷款额度的组合，足以支撑精准的钓鱼、贷款诈骗与定向社工攻击。

第二章 ARTEX 框架深度解析

> *ARTEX 是本次攻击的核心工具。它不是一个传统意义上的漏洞利用框架，而是一个"自主渗透测试 Agent"——将大语言模型作为推理中枢，把传统渗透测试的侦察、利用、验证、报告流程自动化编排。理解 ARTEX 的架构，是理解整个攻击链路的技术基础。*

2.1 框架定位：自主渗透测试 Agent

ARTEX 的全称是 **ARTEX - Autonomous Penetration Testing Framework**（自主渗透测试框架），由开发者 Autumn-27（后曝光真名为 Li Puhua）于 2026 年 7 月 26 日在 GitHub 上以 AGPL-3.0 协议开源发布。

与传统渗透框架（如 Metasploit、Cobalt Strike）的核心区别在于：ARTEX 的**推理中枢不是人类操作员，而是大语言模型**。框架本身负责任务分解、工具调度、结果解析与下一步决策，LLM 负责理解上下文、生成攻击策略、解释工具输出。

表 3 传统框架 vs ARTEX 对比

维度	传统渗透框架	ARTEX（AI Agent）
决策中枢	人类操作员	大语言模型
任务分解	人工规划	LLM 自动拆解目标与子任务
工具调用	手动选择模块	Agent 根据上下文自动选工具
结果解析	人工阅读输出	LLM 解析扫描结果，判断下一步
知识依赖	操作员经验	模型预训练知识 + 实时上下文
速度	受限于人力	可 7×24 持续运行，速度取决于 API 限速

这一定位使 ARTEX 具备两个关键能力：一是**降低技术门槛**——操作者无需精通每一种漏洞利用细节，只需设定目标，框架会自动选择工具并解释结果；二是**规模化的攻击速度**——单个操作者可以并行监控多个目标的自动化渗透流程。

2.2 核心模块与调用链

ARTEX 的架构可分为四个核心模块，形成完整的攻击闭环：

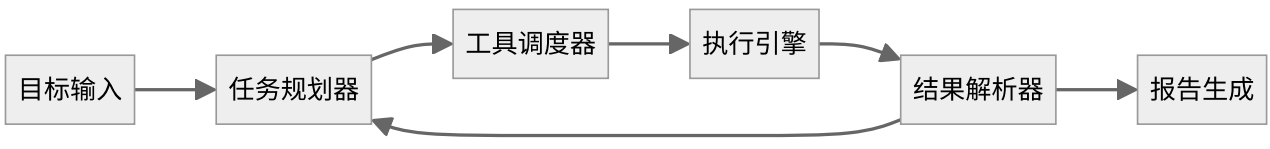


图 1 ARTEX 核心模块调用链

各模块职能如下：

任务规划器（Planner）：接收用户输入的目标（如"渗透 example.com"），调用 LLM 生成阶段性任务列表。例如：端口扫描 → Web 目录枚举 → 漏洞扫描 → 利用尝试 → 权限维持 → 数据提取。

工具调度器（Tool Router）：维护工具库（Nmap、Gobuster、SQLMap、自定义脚本等），根据当前任务阶段和上一轮的执行结果，自动选择下一步要调用的工具及参数。工具库通过插件化架构扩展。

执行引擎（Executor）：在隔离环境（Docker 容器或独立 VPS）中运行选定的工具命令，捕获 stdout/stderr，并将输出回传给结果解析器。支持命令超时、错误重试、资源限制。

结果解析器（Result Parser）：将工具原始输出（常为大段文本）输入 LLM，要求其提取关键信息、判断任务是否完成、识别潜在漏洞、决定下一步行动。这是整个框架的"大脑"所在。

2.3 多模型路由策略

ARTEX 支持通过配置文件接入多个 LLM 提供商，实现模型层面的负载均衡与能力互补。本次攻击中观察到的模型调用策略如下：

表 4 攻击中使用的模型配置

模型	接入方式	在攻击链中的角色
DeepSeek v4.1-flash	经第三方 API 代理 [API-PROXY] 接入	主推理引擎，负责任务规划与结果解析
智谱 GLM-5.3	同 [API-PROXY] 或独立代理	辅助推理，中文语境理解与工具输出解析
xAI Grok 4.6	独立 API 接入	备用模型，处理主模型限流或拒绝的场景
Claude Code	Anthropic 官方 API	人工辅助层，操作员通过对话下指令、审结果

多模型路由的核心价值在于**鲁棒性**：当某一模型因内容安全策略拒绝生成攻击相关指令时，框架可自动切换至另一模型继续执行。此外，不同模型在代码生成、长文本理解、工具输出解析上的能力差异，可以通过互补提升整体成功率。

配置方面，ARTEX 使用 YAML 格式的配置文件定义模型接入参数：

```
# ARTEX 模型配置示例（脱敏处理）
models:
  primary:
    provider: deepseek
    model: deepseek-chat-v4.1-flash
    api_base: https://[API-PROXY]/v1
    api_key: ${DEEPSEEK_API_KEY}
    temperature: 0.7
    max_tokens: 4096

  secondary:
    provider: zhipu
    model: glm-5.3
    api_base: https://[API-PROXY-2]/v1
    api_key: ${GLM_API_KEY}

  fallback:
    provider: xai
    model: grok-4.6
    api_base: https://api.x.ai/v1
    api_key: ${XAI_API_KEY}

routing_strategy: priority_then_fallback
```

值得注意的是，攻击者并未直接使用 DeepSeek 官方 API，而是经由第三方代理 [API-PROXY] 接入。这一设计在隐匿层面增加了额外隔离：DeepSeek 官方日志中看到的是代理商的聚合流量，而非攻击者的直接调用记录。

第三章 双服务器架构与通信链路

> *攻击者的基础设施架构采用了"指挥-执行"双节点分离设计。这种架构在红队操作中极为常见，其设计目标是在"操作可达性"与"身份隔离"之间取得平衡。本章拆解其网络拓扑、流量走向与隐匿逻辑。*

3.1 架构设计思想：指挥与执行分离

双服务器架构的核心思想可以用一句话概括：**操作者只碰指挥节点，攻击流量只从执行节点发出，两者之间通过受控信道转发指令。**

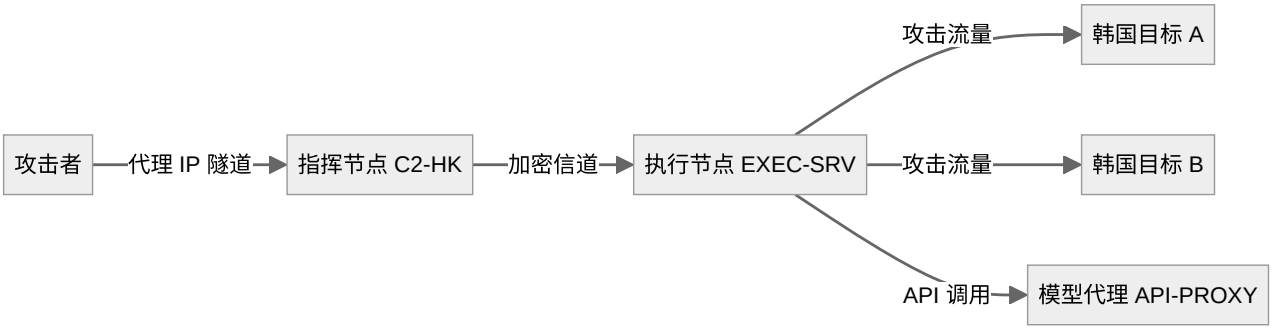


图 2 双服务器架构拓扑概览

两个节点的角色分工如下：

表 5 节点角色与功能对比

维度	指挥节点 [C2-HK]	执行节点 [EXEC-SRV]
地理位置	香港特区（亚太地区枢纽）	境外 VPS 供应商
核心功能	操作员登录、任务下发、结果汇总	运行 ARTEX 实例、发送攻击流量、调用模型 API
暴露面	仅对操作员开放 SSH/Web	对目标与 API 代理开放
日志特征	记录操作员的登录 IP（经代理）	记录攻击流量与 API 调用，无操作员直接痕迹
查封后果	操作员失去控制入口，需重建	取证仅获 ARTEX 配置与运行日志，无直接身份线索

这一架构的防御价值在于**切断直接关联**：即使执行节点被安全团队或执法机关完整查封、镜像分析，其上也不会出现操作者的真实 IP、设备指纹或登录凭证。操作者与执行节点之间的所有交互都通过指挥节点中转。

3.2 流量走向与协议分析

攻击全周期的流量走向可分为三条独立链路，每条链路承担不同职能：

链路一：操作员 → 指挥节点（管理信道）

操作员通过代理 IP 池建立到 [C2-HK] 的 SSH 或 Web 会话。登录前需先穿越跳板代理，使指挥节点看到的源 IP 为代理出口（分布在 9 个不同国家）。该链路承载任务配置、实时监控与结果查看。

链路二：指挥节点 → 执行节点（控制信道）

指挥节点通过预先建立的加密通道（可能是反向 SSH、WebSocket 或自定义协议）向 [EXEC-SRV] 下发任务指令。此信道仅承载控制指令与文本结果，不直接暴露攻击流量特征。

链路三：执行节点 → 目标 + API（攻击与推理信道）

[EXEC-SRV] 同时对外发起两条流量：一是针对韩国金融机构的攻击流量（HTTP/HTTPS 请求、扫描流量等）；二是对 [API-PROXY] 的模型 API 调用（RESTful API，TLS 加密）。这两条流量在时间上是交织的——ARTEX 执行一轮攻击后，立即调用 LLM 解析结果并获取下一步指令。

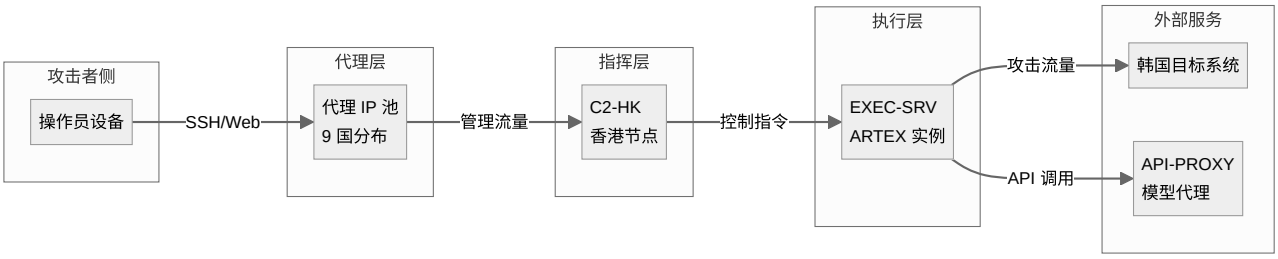


图 3 三层流量走向与协议链路

3.3 代理层与会话隐匿

代理 IP 层是攻击者对外隐匿的第一道防线。本次攻击中观察到的代理特征如下：

- **地理分布**：9 个出口 IP 分布在瑞典、巴西、新加坡、美国等多个司法管辖区
- **使用模式**：每次登录指挥节点时随机切换代理出口，避免单一 IP 的长期关联
- **代理类型**：从行为特征推断为商业 VPN 或代理服务商提供的 SOCKS5/HTTP 代理

代理层的隐匿逻辑在于**切断"操作员物理位置"与"服务器登录记录"之间的直接映射**。指挥节点的登录日志中，源 IP 列显示的是代理出口而非操作员真实地址。即使执法机关调取指挥节点的访问日志，也只能获得一组分散在全球的 IP 列表。

然而，代理层并非绝对安全。代理服务商本身保留日志（包括：谁买了服务、从哪个真实 IP 连接过代理、什么时间用了哪个出口）。这意味着**代理隐匿的可靠性取决于服务商的日志保留政策与司法配合意愿**。在国家级调查中，通过代理服务商的注册与支付记录反查操作者，是标准取证路径之一。

第四章 AI 辅助渗透的技术实现

> *本章进入攻击链的核心——从侦察到数据提取的完整技术实现。ARTEX 框架如何将大模型的推理能力转化为实际的渗透动作？攻击者如何利用 AI 加速每一个传统上需要人工判断的环节？*

4.1 侦察阶段：自动化信息收集

侦察阶段的目标是在不触发告警的前提下，尽可能多地收集目标暴露面信息。ARTEX 在此阶段调用了以下工具链：

子域名枚举

```
# ARTEX 自动生成的侦察指令示例
subfinder -d target-bank.co.kr -all -o subs.txt
assetfinder --subs-only target-bank.co.kr >> subs.txt
amass enum -passive -d target-bank.co.kr -o amass.txt
```

框架将上述工具输出聚合后，交由 LLM 解析：提取有效子域名、识别与业务相关的端点（如 `loan.target-bank.co.kr`、`broker.target-bank.co.kr`）、标记高价值目标优先队列。

端口与服务识别

```
nmap -sC -sV -p- --min-rate 1000 -iL live-hosts.txt -oN nmap-full.txt
```

ARTEX 的 Result Parser 读取 Nmap 输出后，会自动生成摘要："发现 443 端口运行 nginx/1.18.0，8443 端口运行 Tomcat/9.0.65，建议下一步进行 Web 目录枚举与 CVE 匹配。"

Web 目录与接口枚举

```
gobuster dir -u https://broker.target-bank.co.kr -w
/usr/share/wordlists/dirb/common.txt -x php,asp,jsp,html
ffuf -u https://broker.target-bank.co.kr/FUZZ -w /usr/share/wordlists/api-
endpoints.txt -mc 200,201,401,403
```

此处 AI 的价值在于**语义理解**：当 Gobuster 扫出 `/api/v1/loan/status` 时，LLM 能识别这是一个"贷款状态查询接口"，建议尝试参数 fuzz；当扫出 `/admin` 返回 403 时，LLM 建议尝试绕过或寻找其他管理入口。

4.2 攻击阶段：外围系统入侵手法

侦察完成后，ARTEX 进入攻击利用阶段。本次攻击中确认的两类入侵手法如下：

手法一：IDOR（不安全的直接对象引用）枚举

目标系统的贷款查询接口接受客户编号作为参数，格式为顺序递增的纯数字。系统未对访问者身份与查询对象之间的归属关系进行校验——即任意有效会话可以查询任意客户编号的数据。

```
# 请求示例（脱敏）
GET /api/v1/loan/status?customer_id=100001 HTTP/1.1
Host: broker.target-bank.co.kr
Authorization: Bearer {VALID_TOKEN}

# 响应示例
{
  "customer_name": "金某某",
  "phone": "010-XXXX-XXXX",
  "annual_income": 52000000,
  "loan_amount": 150000000,
  "status": "approved"
}
```

攻击者构造的自动化脚本逻辑：

```
import requests, concurrent.futures

def fetch_customer(cid):
    headers = {"Authorization": f"Bearer {TOKEN}"}
    r = requests.get(
        f"https://broker.target-bank.co.kr/api/v1/loan/status",
        params={"customer_id": cid}, headers=headers, timeout=10
    )
    if r.status_code == 200:
        return r.json()
    return None

with concurrent.futures.ThreadPoolExecutor(max_workers=50) as ex:
    results = ex.map(fetch_customer, range(100000, 200000))

valid_records = [r for r in results if r]
# 结果写入本地，后续提取
```

关键成功因素有三：一是**缺乏速率限制**，系统未对单个 Token 的查询频率设限；二是**缺乏范围校验**，未验证 customer_id 是否属于当前登录用户；三是**缺乏异常告警**，50 并发线程在短时间内扫描 10 万个编号，未触发任何 WAF 规则或安全运营中心（SOC）告警。

手法二：员工移动办公系统的弱口令与会话劫持

另一类被确认的目标为员工移动端工作支持系统。该类系统通常面向内部员工，但因业务需要暴露于外网（供远程办公使用）。攻击者在此类系统上使用了以下技术组合：

1. **弱口令爆破**：利用常见密码字典（如 `CompanyName@2024`、`Welcome123` 等变体）对登录接口进行自动化尝试

2. **默认凭证检测**：针对系统默认管理员账号（如 `admin/admin`、`system/password`）进行快速验证
3. **会话固定/劫持**：在成功登录后，提取会话 Cookie 并维持长期有效会话，用于后续数据提取

ARTEX 在此阶段的自动化逻辑：LLM 分析登录页面返回的错误信息（如"用户名或密码错误" vs "账号已锁定"），动态调整爆破策略——当检测到账号锁定时，自动降低频率、切换目标账号，避免触发全面封禁。

4.3 载荷投递与数据提取

数据提取阶段的核心挑战是**如何在不被 DLP（数据防泄漏）系统检测的情况下，将大量数据移出目标环境**。本次攻击中观察到的策略是"低频次、小批量、长时间"。

攻击者未使用传统的 C2 回连通道（如反向 shell、DNS 隧道等），而是利用了一个更隐蔽的路径：

1. **本地聚合**：在执行节点 [EXEC-SRV] 上，ARTEX 将提取的数据按 JSON 格式本地存储，按批次压缩
2. **外传通道**：数据通过 HTTPS 上传至外部存储节点。由于所有流量本就经过 TLS 加密，且上传行为混杂在正常的 API 调用流量中，难以被边界防火墙基于内容检测
3. **清理痕迹**：上传完成后，本地临时文件被覆盖写入随机数据后删除，降低取证恢复概率

数据格式示例（基于公开报告还原）：

```
{
  "source": "broker.target-bank.co.kr",
  "extraction_time": "2026-09-XXTXX:XX:XXZ",
  "records": [
    {
      "customer_id": 100001,
      "name": "金某某",
      "phone": "010-XXXX-XXXX",
      "income": 52000000,
      "loan_amount": 150000000,
      "loan_status": "approved"
    }
  ],
  "total_count": 25000,
  "batch_id": "batch_001"
}
```

从红队视角评估，这一提取策略的"隐蔽性"优于"效率"。如果攻击者的目标是最大化数据量，使用传统 C2 通道或云存储直连会更快；但如果目标是**降低被检测概率**，将提取行为伪装为正常的 API

数据交换，确实是更优选择。

第五章 身份隐匿与反溯源策略

> *攻击者在身份隐匿上投入了大量设计精力。从代理 IP 到双服务器分离，从 API 代理到支付匿名化，每一层都旨在切断"攻击行为"与"真实身份"之间的关联。本章系统拆解其四层隐匿架构。*

5.1 四层隔离架构

攻击者的完整隐匿架构可分为四层，每层解决不同阶段的溯源风险：

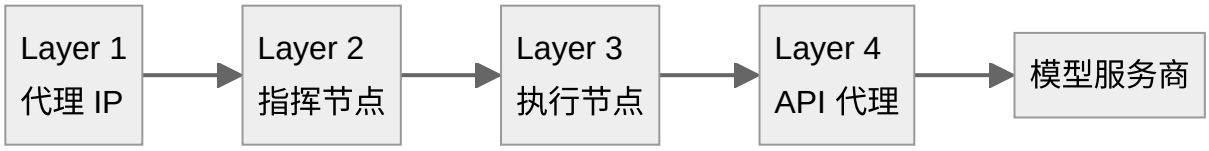


图 4 四层隔离架构

表 6 四层隔离详细说明

层级	功能	防溯源对象	风险点
Layer 1 代理 IP	操作员登录指挥节点前先进跳板	指挥节点登录日志	代理服务商日志、支付记录
Layer 2 指挥节点	中转所有操作指令，隔离操作员与执行节点	执行节点被查封后的取证分析	节点本身的购买记录、备份数据
Layer 3 执行节点	实际发起攻击，所有对外流量从此出	目标侧看到的攻击源	节点上留存的工作日志、配置文件
Layer 4 API 代理	模型调用经第三方代理中转	模型服务商的原始调用日志	代理商的注册与充值记录

这一架构的核心设计原则是：**任何单一节点被完整控制，都不应直接暴露操作者身份**。执行节点被查封 → 只有攻击工具和日志；指挥节点被查封 → 只有代理 IP 的登录记录；API 代理被查封 → 只有聚合的流量日志。

5.2 支付与注册匿名化

隐匿架构的物理基础是服务器和服务的购买。标准的红队匿名化流程如下：

服务器购买匿名化

1. 使用加密货币（BTC/XMR/USDT）支付 VPS 费用，避免信用卡/支付宝的实名绑定
2. 注册时使用一次性邮箱（如 ProtonMail、Tutanota），邮箱本身通过 Tor 或代理注册
3. 购买时同样通过代理 IP 访问服务商网站，避免真实 IP 与订单关联
4. 优先选择不要求 KYC（实名认证）的境外服务商

API 代理匿名化

1. API 代理账号使用与服务器不同的邮箱注册
2. 充值使用加密货币或礼品卡，避免银行流水关联
3. 代理服务本身支持多用户共享 API key，进一步模糊个体用量

需要指出的是，**"匿名化"不等于"不可追溯"**。执法机关可以通过以下路径突破：

- 向 VPS 服务商发送司法协助请求，获取注册邮箱、支付地址、订单 IP
- 向加密货币交易所发送协助请求，追踪 USDT 的链上来源与提现记录
- 向代理服务商发送协助请求，获取代理账号的注册信息与充值记录

匿名化的本质不是"让溯源不可能"，而是"让溯源成本足够高"——需要跨国司法协作、链上分析、多源数据关联，时间与资源成本呈指数级上升。

5.3 行为指纹控制

除了基础设施层面的隔离，攻击者还需控制"行为指纹"——即从操作习惯、时间规律、语言特征中提炼出的软身份标识。CrowdStrike 在报告中指出攻击者为"中文使用者、财务动机"，正是基于以下行为指纹：

表 7 已知行为指纹与反制策略

指纹类型	观察特征	理想反制策略
时区规律	操作时间集中在 UTC+8 夜间（操作者本地时间）	使用自动化脚本按 UTC 工作时间运行，人工仅在必要时介入
语言习惯	Prompt 与配置文件使用中文	所有自动化 Prompt 使用英文，人工交互也通过英文进行
工具偏好	使用中国开发的开源工具（ARTEX）	混合使用多国工具，避免单一来源偏好
目标选择	集中攻击韩国金融机构	目标地理分散，避免明显的地缘政治指向
变现模式	搜索数据贩卖渠道（Telegram 群组）	避免在攻击工具的同一会话中讨论变现

从本次攻击的实际情况看，攻击者在行为指纹控制上表现参差不齐：时区规律未做有效掩饰（操作时间仍暴露 UTC+8 特征），语言习惯也未做隔离（中文 Prompt 直接写在配置文件中）。这为安全分析人员提供了重要的归因线索。

第六章 致命失误与暴露分析

> *攻击者在基础设施隔离和行为控制上投入了大量设计，但最终却因为两个低级失误而全盘暴露。本章拆解这两个失误的技术细节、发生原因与可防范措施。这是整个事件中最具教育意义的部分。*

6.1 目录浏览：一个默认配置的灾难

攻击者在执行节点 [EXEC-SRV] 上运行了 ARTEX 的 Web 控制台，监听在 18899 端口。该控制台本应仅对操作者本人可达，但攻击者犯了一个致命错误：**未关闭 Web 服务器的目录浏览（Directory Listing）功能**。

目录浏览是 Web 服务器的一项默认功能。当开启时，访问一个目录路径（如 `http://[EXEC-SRV]:18899/.claude/`）将返回该目录下所有文件的列表，而非 403 Forbidden。这意味着任何人无需认证即可浏览服务器上的文件结构。

```
# Nginx 配置示例：目录浏览的开关
# 默认开启（危险）
autoindex on;

# 正确配置（关闭）
autoindex off;

# 或限制访问范围
location / {
    autoindex off;
    allow 10.0.0.0/8;    # 仅内网
    deny all;
}
```

攻击者服务器上暴露的目录结构（基于公开报告还原）：

```
http://[EXEC-SRV]:18899/
├── .claude/
│   ├── CLAUDE.md          # 写给 Claude 的系统指令
│   ├── sessions/          # Claude Code 会话历史
│   │   ├── session_2026-09-xx.json
│   │   └── session_2026-10-xx.json
│   └── memory/            # Claude 记忆文件
├── artex/
│   ├── config.yaml        # ARTEX 主配置
│   ├── logs/
│   └── payloads/
└── workspace/
    └── extracted_data/    # 提取的数据缓存
```

安全研究人员发现这一暴露面的过程极为简单：用浏览器访问 IP 加端口，点击目录链接，直接下载文件。**没有利用任何漏洞，没有破解任何密码**——相当于抢劫犯把作案计划书放在了没锁的抽屉里，警察打开抽屉就拿走了。

> **红线警示**
>
> 目录浏览不是"高级配置失误"，而是部署清单上最基础的一项检查。任何生产环境、测试环境、乃至个人实验环境的 Web 服务，上线前必须确认：autoindex = off；管理界面绑定范围 = 白名单；无需对外暴露的端口 = 防火墙关闭。

6.2 日志管理：自己写下的证据链

暴露的目录中，最具破坏力的是 `CLAUDE.md` 和 `sessions/` 目录下的会话历史。这些文件完整记录了攻击者与 AI 的每一次交互，构成了一条自我书写的证据链。

CLAUDE.md 是攻击者写给 Claude Code 的系统指令文件，内容以中文撰写，包含渗透测试的目标范围、工具使用偏好、输出格式要求等。这份文件直接证明了：

- 操作者的母语为中文
- 对目标系统的认知程度（知道哪些接口、哪些参数）
- 攻击意图的明确表达

会话历史 则以 JSON 格式完整保存了每一轮对话的输入与输出。CrowdStrike 的分析人员通过阅读这些会话，完整还原了攻击的时间线、使用的技术、遇到的问题与调整策略。

从红队视角反思，这一失误的根源在于对 AI 工具的**日志机制缺乏理解**。Claude Code 默认将工作目录下的 `.claude/` 作为持久化存储空间，会话历史、记忆、配置文件全部保存在此处。攻击者可能认为"这是我自己的服务器，文件存在这里很安全"，却忽略了 Web 服务对这些文件的可达性。

6.3 身份信息注入：Prompt 里的裸奔

如果说目录浏览是"门没锁"，那么以下操作就是"在日记里写上了真名"——攻击者在某次会话中，要求 Claude 帮他撰写一份"网络安全研究员简历"，并在 Prompt 中提供了自己的真实信息：

```
# 会话内容还原（基于公开报告）
用户：帮我写一份网络安全研究员的简历，以下是我的信息：
- 年龄：26 岁
- 学校：华南理工大学
- 所在地：广东茂名
- 电话：178XXXXXXXX
- Telegram：@YY520CN
- 技能：渗透测试、漏洞挖掘、AI 安全研究
```

这段对话被完整保存在会话历史文件中，与其他攻击相关的对话躺在同一个开放目录里。安全研究人员发现这一内容后，立即获得了一组高度具体的身份线索：

表 8 从简历 Prompt 中提取的身份线索

线索	验证可能性	实际验证状态
年龄 26 岁	无法独立验证	CrowdStrike：中等置信度
华南理工大学	校友数据库、学籍系统	未公开验证
广东茂名	电话归属地、IP 地理定位	电话归属地匹配
电话 178XXXXXXXX	直接拨打、运营商协查	路透社记者拨打，对方称不知情
Telegram @YY520CN	账号活跃度、历史发言	已确认活跃，10/8 发文回应

更深层的关联在于：**这个 Telegram 账号不仅出现在攻击会话中，还出现在其他犯罪场景的调研记录里**——包括 NFT 礼品市场研究、对中国某支付平台的渗透尝试。同一个账号在多个独立场景中复用，使得安全分析人员能够高度确信这些活动出自同一人之手。

从红队视角的教训极为清晰：**Prompt 不是草稿纸，是会被保存、会被读取、会被取证的正式文档**。任何写入 Prompt 的真实身份、敏感信息、犯罪意图，都会以明文形式保存在模型服务商和本地日志的双重存档中。

第七章 防御视角与检测建议

> *本章从蓝队（防御方）视角出发，基于前述攻击链的技术特征，提出可落地的检测与防御建议。理解攻击者的能力边界与失误模式，是构建有效防御的前提。*

7.1 资产暴露面收敛

本次攻击的成功前提，是目标机构存在可被外部访问的外围系统。这些系统往往因业务需求而暴露，但缺乏与核心系统同等级别的防护。

最小暴露原则

- 员工移动办公系统：优先采用 VPN 接入，而非直接暴露于公网
- 第三方经纪人/渠道接口：通过 API 网关统一接入，实施严格的认证、授权与审计
- 内部管理后台：禁止任何公网可达性，仅允许办公内网或零信任网络访问

接口加固清单

表 9 外围系统接口加固检查项

检查项	风险描述	修复建议
IDOR 漏洞	顺序递增 ID 可被批量枚举	改用 UUID 或哈希 ID；实施行级权限校验
速率限制缺失	单 Token 可高频请求	按 Token + IP 维度限流；异常频率触发告警
弱口令策略	员工使用简单密码	强制 MFA；密码复杂度策略；定期弱口令扫描
默认凭证	系统自带管理员账号未修改	部署前强制修改所有默认凭证；定期审计
会话管理缺陷	会话长期有效、无并发控制	短时效 Token；单点登录限制；异常登录告警

7.2 AI 辅助攻击的检测特征

AI 辅助攻击与传统攻击在行为模式上存在可识别的差异。安全运营团队可参考以下特征建立检测规则：

请求行为特征

- **超人类速度**：AI 可以在数秒内完成传统需要数分钟的人工决策。同一 Token 在 1 分钟内调用 10 个不同接口，且参数组合呈现系统化遍历特征，高度疑似自动化
- **参数空间遍历**：请求参数呈现顺序递增、等差分布、或字典式排列，而非人类用户的随机访问模式
- **无"探索性"行为**：人类用户通常会先浏览页面、点击多个菜单再执行操作；AI 直接命中 API 端点，缺乏前置的页面交互

流量特征

- 攻击流量与 LLM API 调用流量高度交织：同一源 IP 在短时间内既访问目标系统，又向已知 LLM API 端点发送大量 HTTPS 请求
- User-Agent 异常：ARTEX 及类似工具通常使用固定的 HTTP 客户端标识（如 Python requests、自定义 Agent 字符串）

日志分析规则

```
# WAF/防火墙检测规则示例
# 规则 1：高频顺序 ID 查询
alert when:
  source_ip = single_ip AND
  endpoint = "/api/v1/loan/status" AND
  count(distinct customer_id) > 100 AND
  time_window = 60s

# 规则 2：无页面交互直接 API 调用
alert when:
  first_request.endpoint = "/api/v1/loan/status" AND
  no_referer AND
  no_prior_html_page_views

# 规则 3：AI API 与攻击目标共现
alert when:
  source_ip connects to known_llm_api_endpoints AND
  source_ip connects to internal_financial_systems
```

7.3 运维 Hygiene 检查清单

攻击者的暴露源于运维层面的基础疏忽。以下检查清单适用于任何运行 Web 服务、AI Agent 工作台或渗透测试环境的场景：

表 10 运维 Hygiene 检查清单

编号	检查项	检查命令/方法	合格标准
1	目录浏览关闭	curl -I http://localhost/任意目录/	返回 403，非文件列表
2	管理端口白名单	iptables -L / ufw status	仅允许指定 IP 访问管理端口
3	服务监听范围	ss -tlnp	管理端口绑定 127.0.0.1 或内网 IP
4	日志文件权限	ls -la /var/log/ /opt/*/logs/	日志目录 Web 服务用户无权读取
5	敏感文件位置	find /var/www -name "*.key" -o -name ".env"	密钥、配置不在 Web 根目录
6	会话历史清理	检查 ~/.claude/ /tmp/ 等	敏感会话定期归档或加密
7	Prompt 信息审计	review 近期 Prompt 日志	无真实身份、电话、地址、密钥
8	备份与快照安全	检查云厂商快照/镜像	敏感数据快照加密、访问受限

> **核心原则**
>
> AI 能力再强，也架不住基础设施层面的基础疏忽。攻击者的技术设计（多层代理、双服务器分离、多模型路由）体现了较高的工程能力，但一个默认开启的目录浏览配置，就把全部设计归零。防御方不需要比攻击者更聪明，只需要把基础项做到位。

simon

一个不懂代码的 AI 极客

微信交流群：simonsxxs

GitHub：github.com/simonsxxs

Gitee：gitee.com/simonsxx

本文基于公开安全报告与技术资料整理，仅供安全研究与防御建设参考。

任何利用本文所述技术从事非法活动的行为，与作者无关。